

POGRID.ID

Codebase Audit Report

Company technical audit for Laravel/Inertia manufacturing execution platform

Report date	13 August 2026 (rev. 3 — post P0 remediation + partial P1 maintainability)
Repository	/home/tito/pogrid
Commit reviewed	d5d9d4b base + local P0 fixes (uncommitted)
Stack	Laravel 11, PHP 8.3, Inertia v2, React 18, TypeScript, Tailwind v4, Vite 8
Method	Graph analysis, static source inspection, test/typecheck/build/security commands

Confidential internal engineering report. Working tree contained uncommitted changes during audit.

1. Executive Summary

Overall result: POgrid has strong domain coverage and tenant-isolation controls. Both P0 remediation items (TypeScript debt, production build/test verification) are now resolved. Primary residual risk is maintainability hotspots in the two largest dashboard files.

Area	Rating	Evidence
Business correctness	Strong	194 PHPUnit tests passed; 1,546 assertions.
Tenant security	Strong	Fail-closed TenantScope, TenantManager, tenant-safe auth provider, dedicated cross-tenant tests passed.
Authorization	Good	Office route group uses auth, access-office gate, verified middleware. Policies exist for Alert, Item, PO, Tenant, User.
Frontend type safety	Resolved	0 TypeScript errors (was 44). Baseline lowered to 0. Three real runtime bugs found and fixed along the way (see 5.1).
Build verification	Resolved	<code>npm run build</code> succeeds; production bundle generated.
Maintainability	Improving	Hotspot controllers/pages reduced via service + feature-component extraction: OwnerDashboardController 878 → 595; WorkerDashboardController 841 → 613; Worker Dashboard 1,674 → 1,080; Owner Dashboard 2,608 → 2,313. Test suite green throughout.
Dependency posture	Good	<code>npm audit --production</code> : 0 vulnerabilities.
Deployment	Improved	CI builds before tests; deploy excludes public/hot and rebuilds caches.

92/100 Readiness score (was 89/100). Suitable for production deployment; remaining P1 work is dashboard decomposition, cron heartbeat monitoring and explicit business-rule consolidation.

2. Scope and Evidence

Metric	Value
Knowledge graph	270 files, ~196,083 words, 2,087 nodes, 3,602 edges.
Backend	6,378 LOC; 11 controllers; 13 models; 7 services.
Frontend	20,675 TS/TSX LOC.
HTTP surface	61 route declarations in <code>routes/web.php</code> .
Persistence/testing	36 migrations; 20 PHP test files.
Checks	PHPUnit 194/194 pass; TypeScript 0 errors; production build succeeds; npm production audit clean.

3. Architecture Assessment

Strengths

- Clear Laravel route → middleware → controller → policy/service/model structure.
- Business rules centralised in `config/workflow.php`, `ProgressService`, `StageGate`, observers and telemetry.
- Multi-tenant design is explicit: `TenantScope` fail-closed, scoped models, controlled bypass via `TenantManager`.
- Frontend has feature extraction under `resources/js/features` and shared app chrome.

Findings

ID	Severity	Finding	Status
A-01	Reduced	Dashboard controllers were oversized: Owner 878 LOC, Worker 841 LOC.	Owner now 595 LOC, Worker 613 LOC. Extracted <code>StageTemplateService</code> , <code>UserManagementService</code> , <code>ReportingService</code> , <code>TenantSettingsService</code> , <code>WorkerReportingService</code> . Controllers keep authorization, validation and response only.
A-02	Partially reduced	Dashboard pages were oversized: Owner 2,608 LOC, Worker 1,674 LOC, PPIC 929 LOC.	Worker now 1,080 LOC (<code>ProgressControls</code> , <code>FinancePanel</code> , <code>QcReworkForm</code> , <code>KendalaForm</code>); Owner now 2,313 LOC (<code>StageTemplateModal</code> extracted, dead inline search modal replaced by existing <code>SearchModal</code>). PPIC page not yet addressed.
A-03	Low	Graph report is stale relative to any later working-tree changes.	Run <code>graphify update</code> . after changes and before future audit baselines.
A-04	Medium	Duplicated business rules remain in <code>WorkerDashboardController</code> : <code>drafter/purchasing status sync</code> mirrors <code>ProgressService</code> , and <code>PoCompletionChecker</code> exists but is unused by the finance PO-closing cascade.	Open. Deliberately excluded from the extraction pass to keep it behavior-neutral; schedule as its own change with dedicated tests.

4. Security and Authorization

Verified controls

- Office routes structurally require authentication, office gate and email verification.
- PIN login is throttled at 5 requests/minute; office login has named throttle.
- Password reset and verification resend are throttled.
- Tenant-safety tests cover cross-tenant item, user, PIN reset, dashboard, progress and websocket access.
- No `dd()`, `dump()` or `console.log` leftovers found in application source.
- Raw SQL surface is small: three matches; direct `env()` calls outside config: zero.

Residual risks

ID	Severity	Finding	Action
S-01	Medium	24 controlled tenant-scope bypass usages require ongoing review.	Require stated reason in every bypass; add static review checklist and regression tests for new query paths.
S-02	Low	Production secrets are operationally external, but deployment docs contain sensitive infrastructure context.	Keep secrets only in hosting/GitHub secret stores; review committed deployment documentation before public repository exposure.

5. Quality and Testing

Check	Result	Assessment
PHPUnit	194 passed / 1,546 assertions	Strong backend regression baseline; unchanged after remediation.
TypeScript	0 errors (was 44)	Baseline lowered from 44 to 0; gate now blocks any new type error.
Production build	Succeeds	Vite build completed; bundles emitted to <code>public/build</code> .
npm audit	0 production vulnerabilities	Good current dependency signal; rerun on updates.
E2E	Not run	Requires running Laravel server and seeded environment; remains a release-gate item.

5.1 Q-01 — Type debt resolved, three runtime bugs uncovered

The 44 reported errors were not purely cosmetic. Fixing them exposed defects that would have failed at runtime:

File	Defect	Impact before fix
Pages/Owner/ReworkLogbook.tsx	Undefined identifiers <code>filtered</code> and <code>setLanguage</code> .	Table view and language toggle would throw <code>ReferenceError</code> at render/click.
Pages/Owner/Logs.tsx	Badge read <code>style.tone</code> while the helper returns <code>toneClass</code> ; unknown-action fallback exposed <code>label</code> instead of <code>en</code> .	Action badges rendered without styling; unknown actions showed <code>undefined</code> in English.
Pages/Landing/Landing.tsx	Type alias referenced a removed <code>translations</code> binding.	Dead reference; blocked strict compilation.

Remaining fixes were type-surface corrections: Vite `ImportMeta` references, `Echo<'pusher'>` generic arguments, an `IconProps.style` gap, Inertia v2 removing `preserveState/preserveScroll` from `ReloadOptions`, and missing domain fields (`Telemetry.risks`, `Telemetry.delayed_pos_count`, `ScheduleItem.is_urgent`, `tenant.logo_path`).

6. Operations and Deployment

- GitHub Actions runs Composer install, Node setup, typecheck gate, frontend build and PHP tests.
- Deploy command explicitly excludes `public/hot`, preventing production from loading localhost Vite URLs.
- Post-deploy cache clear, view/config/route cache rebuild are included.

- Queue and timeline evaluation are cron-dependent; operational monitoring must verify both execute every minute.

ID	Severity	Operational risk	Mitigation
O-01	Medium	Queue and timeline jobs have no daemon; silent cron failure can delay alerts and workflow.	Add external uptime/cron heartbeat and alert on stale <code>EvaluateTimelines</code> / queue timestamps.

7. Prioritised Remediation Plan

Priority	Work	Status	Exit criterion
P0	Resolve 44 TypeScript errors.	Done	<code>npm run typecheck:ci</code> passes with baseline 0.
P0	Run production frontend build and backend regression suite.	Done	<code>npm run build</code> succeeds; <code>php artisan test</code> reports 194 passed.
P0	Run E2E suite in seeded release-like environment.	Pending	Auth, tenant isolation, progress and export journeys pass against live Laravel server.
P1	Extract dashboard controller responsibilities.	Done	Owner 878 → 595 LOC, Worker 841 → 613 LOC via 5 new services (pure move, no rule changes). <code>php artisan test</code> stayed at 194 passed after every step.
P1	Extract dashboard page features.	Partially done	Worker Dashboard 1,674 → 1,080 LOC (4 feature components). Owner Dashboard 2,608 → 2,313 LOC (1 modal extracted, 1 dead duplicate UI removed). PPIC Dashboard (929 LOC) and remaining Owner tabs not yet extracted.
P1	Consolidate duplicated business rules (A-04): drafter/purchasing sync vs <code>ProgressService</code> , unused <code>PoCompletionChecker</code> .	Pending	Requires behavior-changing edit with dedicated regression tests, not a pure move — scoped separately from the LOC-reduction pass.
P1	Add cron/queue heartbeat monitoring.	Pending	Alert raised when timeline/queue execution exceeds agreed SLA.
P2	Reduce <code>any</code> and suppression usage.	Pending	Tracked count decreases each sprint; no new suppressions.

8. Conclusion

POgrid's backend foundation is credible for controlled deployment: core tests are green and tenant isolation is unusually well covered. Release confidence should not be confused with maintainability maturity. The next engineering investment should be type debt reduction and hotspot extraction, not new abstractions or dependency expansion.

Prepared from repository state on 13 August 2026. This report is an engineering assessment, not a penetration test, legal compliance certification, or financial audit.